

HỌC VIỆN NGÂN HÀNG
KHOA CÔNG NGHỆ THÔNG TIN & KINH TẾ SỐ



CHƯƠNG VI

ĐẢM BẢO AN TOÀN CHO HỆ THỐNG THÔNG TIN

Nội dung

6.1

Đảm bảo an toàn bằng mô hình nhiều lớp

6.2

Các kiến trúc an toàn cho HTTP

6.3

Một số giải pháp an toàn cho HTTP

6.4

Một số giải pháp an toàn cho người dùng

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.1 Khái niệm

- ❖ **Khái niệm:** là chiến lược thiết kế an toàn thông tin dựa trên việc xây dựng nhiều lớp phòng thủ độc lập nhưng hỗ trợ lẫn nhau. Khi một lớp bị vượt qua, các lớp khác vẫn tiếp tục bảo vệ hệ thống
- ❖ **Nguyên lý cốt lõi:**
 - ❑ Không tin tưởng bất kỳ thành phần nào
 - ❑ Giả định hệ thống có thể bị xâm nhập
 - ❑ Tăng chi phí và độ phức tạp cho kẻ tấn công

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp vật lý (Physical Security):

- ❑ Kiểm soát truy cập vật lý
- ❑ Camera giám sát, hệ thống báo động
- ❑ Bảo vệ trung tâm dữ liệu (Data Center)

Mục tiêu: Ngăn chặn truy cập trái phép vào hạ tầng phần cứng

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp mạng (Network Security):

- ❑ Tường lửa
- ❑ Hệ thống phát hiện xử lý xâm nhập (IDS/IPS)
- ❑ VPN, phân loại đoạn mạng

Mục tiêu: Ngăn chặn truy cập trái phép và kiểm soát lưu lượng mạng

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp hệ thống (Host/Endpoint Security):

- ❑ Antivirus/EDR
- ❑ Quản lý các bản vá
- ❑ Cấu hình hệ điều hành an toàn

Mục tiêu: Bảo vệ máy chủ, máy trạm khỏi mã độc và khai thác lỗ hổng

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp ứng dụng (Hot/Endpoint Security):

- ❑ Kiểm tra bảo mật ứng dụng (SAST, DAST)
- ❑ Xác thực và phân quyền
- ❑ Bảo vệ API

Mục tiêu: Ngăn chặn các lỗ hổng như SQL injection, XSS

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp dữ liệu(Data Security):

- ❑ Mã hóa dữ liệu (Encryption at rest & in transit)
- ❑ Quản lý khóa (Key Management)
- ❑ Phân loại và kiểm soát truy cập dữ liệu

Mục tiêu: Bảo vệ dữ liệu – Tài sản quan trọng nhất

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp con người (human layer):

- ❑ Đào tạo nhận thức an toàn thông tin
- ❑ Chính sách và quy trình
- ❑ Kiểm soát nội bộ

Mục tiêu: Giảm thiểu rủi ro từ con người – mắt xích yếu nhất

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.2 Các lớp trong mô hình bảo mật nhiều lớp

❖ Lớp giám sát và phản ứng (Monitor & Response):

- ❑ SOC (Security Operations Center)

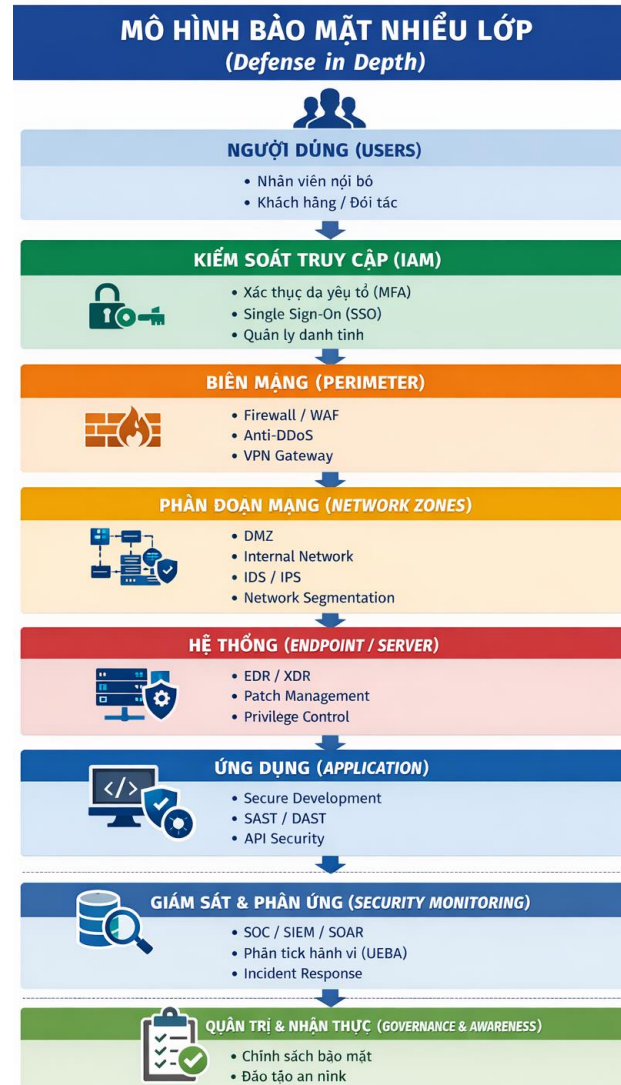
- ❑ SIEM, SOAR

- ❑ Kiểm soát nội bộ

Mục tiêu: Phát hiện sớm, phản ứng nhanh và giảm thiểu thiệt hại

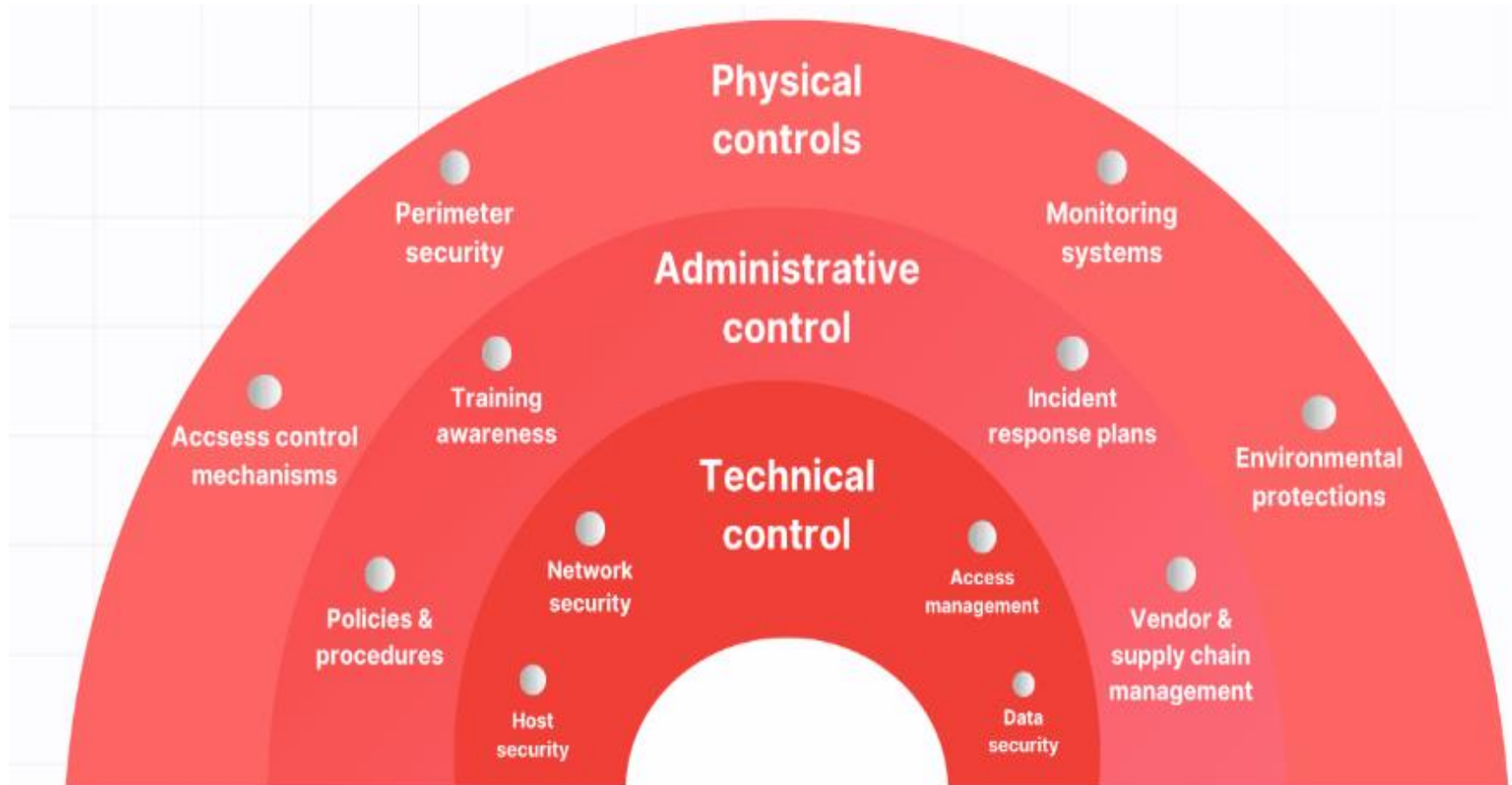
6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.3 Mô hình minh họa kiến trúc nhiều lớp



6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.3 Mô hình minh họa kiến trúc nhiều lớp



6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.4 Ưu điểm của mô hình nhiều lớp

- ❖ Tăng khả năng phòng thủ
- ❖ Giảm thiểu rủi ro đơn điểm
- ❖ Phát hiện sớm và phản ứng nhanh
- ❖ Tuân thủ tiêu chuẩn (ISO27001, NIST, CIS)

6.1. Đảm bảo an toàn bằng mô hình nhiều lớp

6.1.5 Thách thức khi triển khai

- ❖ Chi phí cao: Công nghệ + Vận hành
- ❖ Phức tạp trong quản lý
- ❖ Cần tích hợp giữa các hệ thống
- ❖ Đòi hỏi nhân lực có chuyên môn

6.2. Các kiến trúc an toàn cho HTTP

6.2.1 Kiến trúc phòng thủ nhiều lớp

- ❖ **Đặc điểm: triển khai nhiều lớp bảo vệ**
- ❖ **Thành phần**
 - ❑ Tường lửa, IDS/IPS
 - ❑ Endpoint Security
 - ❑ Application Security
 - ❑ Data Encryption
- ❖ **Ưu điểm: Giảm thiểu rủi ro tổng thể, tăng khả năng phát hiện tấn công**

6.2. Các kiến trúc an toàn cho HTTT

6.2.2 Kiến trúc Zero Trust

- ❖ **Đặc điểm: Không tin ai, xác thực liên tục**
- ❖ **Thành phần**
 - ❑ **IAM – quản lý danh tính và quyền truy cập**
 - ❑ **MFA – Xác thực đa nhân tố**
 - ❑ **Microsegmentation**
- ❖ **Ưu điểm: Phù hợp với môi trường Cloud, ngăn chặn Lateral Movement**

6.2. Các kiến trúc an toàn cho HTTP

6.2.3 Kiến trúc Phân vùng mạng

- ❖ Mô hình: Internet -> DMZ -> Internal Network -> Security Zone
- ❖ Kỹ thuật
 - ❑ VLAN
 - ❑ Subnet
 - ❑ Firewall nội bộ
- ❖ Mục tiêu: Cô lập hệ thống quan trọng, giảm phạm vi ảnh hưởng khi bị tấn công

6.2. Các kiến trúc an toàn cho HTTT

6.2.4 Kiến trúc SOC

- ❖ Thành phần: SIEM, SOAR, Threat Intelligence
- ❖ Chức năng: Giám sát 24/7, phát hiện và phản ứng sự cố
- ❖ Đặc điểm:
 - ❑ Là lớp giám sát ngang
 - ❑ Tích hợp với các hệ thống khác

6.2. Các kiến trúc an toàn cho HTTT

6.2.5 Kiến trúc bảo mật dữ liệu

- ❖ Trọng tâm: Dữ liệu là tài sản quan trọng nhất
- ❖ Thành phần: Encryption, Data Masking, DLP
- ❖ Áp dụng: Ngân hàng, y tế, chính phủ

6.2. Các kiến trúc an toàn cho HTTT

6.2.6 Kiến trúc bảo mật Cloud

❖ Mô hình: **Shared Responsibility Model**

❖ Thành phần: **CSPM, CWPP, CASB**

❖ Đặc điểm:

❑ **Linh hoạt, mở rộng cao**

❑ **Rủi ro cấu hình sai**

6.2. Các kiến trúc an toàn cho HTTT

6.2.7 Kiến trúc XDR (Extended Detection & Response)

❖ Phát triển từ: EDR → NDR → XDR

❖ Chức năng: Thu thập dữ liệu từ Endpoint, Network, Email, Cloud

❖ Ưu điểm:

❑ Phát hiện tấn công đa điểm

❑ Tự động hóa phản ứng

6.2. Các kiến trúc an toàn cho HTTT

Kiến trúc	Trọng tâm	Phù hợp
Defense in Depth	Lớp bảo vệ	Mọi hệ thống
Zero Trust	Danh tính	Cloud, hybrid
Network Segmentation	Mạng	Data center
SOC	Giám sát	Doanh nghiệp lớn
Data-Centric	Dữ liệu	Ngân hàng
Cloud Security	Hạ tầng cloud	SaaS/IaaS
XDR	Phát hiện nâng cao	SOC hiện đại

6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.1 Tổng quan về các giao thức bảo mật trên Web

- ❖ **Secure socket layer (SSL) cung cấp dịch vụ an toàn giữa TCP và ứng dụng dùng TCP.**
- ❖ **Transport layer service (TLS) là phiên bản tiêu chuẩn Internet.**
- ❖ **SSL/TLS dùng mã hóa mã hóa đối xứng và mã chứng thực message**

6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.1 Tổng quan về các giao thức bảo mật trên Web

- ❖ **SSL/TLS** bao gồm những kỹ thuật về giao thức để cung cấp dịch vụ an toàn.
- ❖ **Secure electronic transaction (SET)** là một đặc tả an toàn và mã hóa mở cho phép giao dịch bằng thẻ tín dụng trong Internet

6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.2 Thách thức về Internet

- ❖ Internet với môi trường phức tạp, tương tác dễ bị tấn công.
- ❖ Web cung cấp thông tin và giao dịch thương mại, nếu bị tấn công sẽ gây ra thiệt hại lớn.
- ❖ Những phần mềm dùng trong Web phức tạp và chứa đựng nhiều rủi ro về an toàn, có nhiều loại tấn công đã được sử dụng

6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

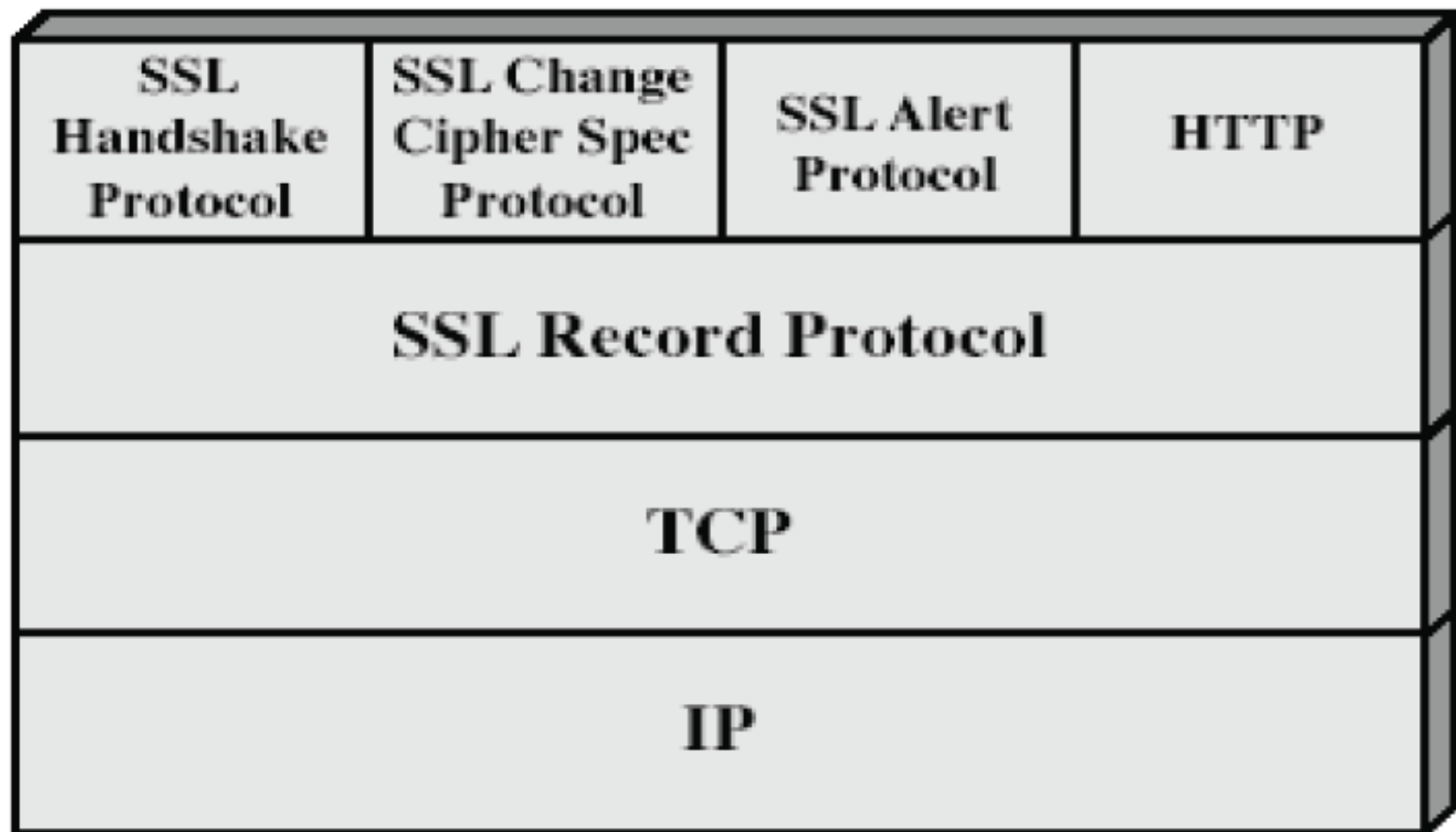
6.3.1.2 Thách thức về Internet

- ❖ Web server là nơi có thể bị khai thác để xâm nhập vào hệ thống.
- ❖ Hầu hết người sử dụng dịch vụ Web là những người không thông thạo và không được huấn luyện

6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL



6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ SSL Record Protocol

❑ Dịch vụ cung cấp: cung cấp 2 dịch vụ:

- Tin cậy (Confidentiality): giao thức bắt tay xác định một khóa bí mật chia sẻ mà được dùng cho việc mã hóa thông thường.
- Toàn vẹn thông điệp (Message Integrity): giao thức bắt tay xác định một khóa bí mật chia sẻ mà được dùng để hình thành một MAC (message authentication code)

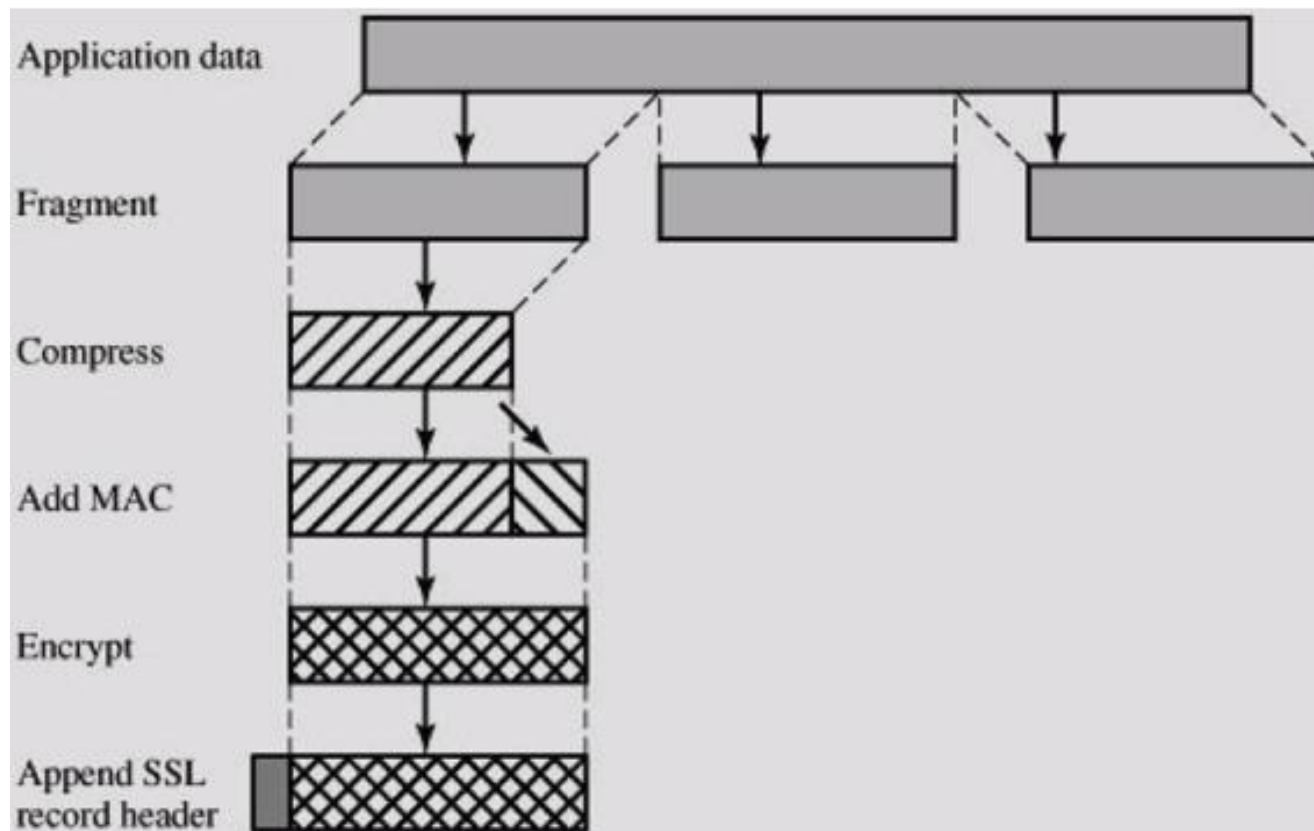
6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ SSL Record Protocol

□ Hoạt động:



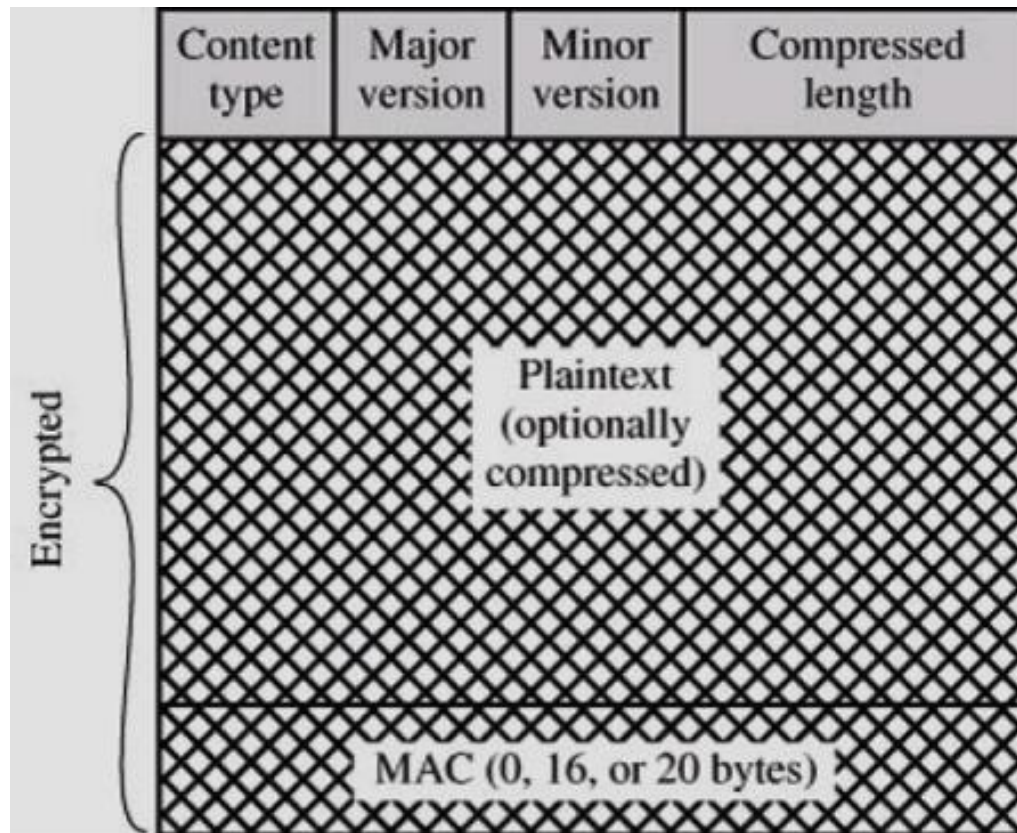
6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ SSL Record Protocol

□ Định dạng của SSL Record:



6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ Change Cipher Spec Protocol

Mục đích duy nhất của Msg này là để gây ra trạng thái chờ để được copy vào trạng thái hiện hành



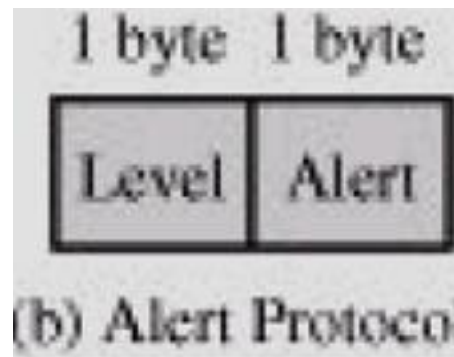
6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ Alert Protocol

- ❑ Byte đầu tiên nhận giá trị warning (1) hay fatal (2). Nếu fatal SSL ngay lập tức kết thúc kết nối, các kết nối khác cùng session có thể tiếp tục nhưng không có kết nối mới nào trong session này được thành lập
- ❑ Byte thứ hai chứa một mã mà xác định cảnh báo đặc trưng



6.3. Một số giải pháp an toàn cho HTTP

6.3.1. An toàn Web

6.3.1.3 Kiến trúc SSL

❖ Handshake Protocol (Giao thức bắt tay)

- ❑ Là phần phức tạp nhất của SSL
- ❑ Giao thức này cho phép client và server chứng thực lẫn nhau và giao tiếp để xác định việc mã hóa, giải thuật MAC và khóa mã hóa được dùng để bảo vệ dữ liệu gửi trong record SSL
- ❑ Giao thức bắt tay được dùng trước khi dữ liệu ứng dụng được truyền

❏ Giao thức bắt tay

- 1: Xác định phiên bản cao nhất của giao thức SSL/TLS, một mã số ngẫu nhiên, một danh sách các bộ mật mã và phương pháp nén
- 2: Gồm phiên bản giao thức được chọn, mã số ngẫu nhiên, bộ mật mã và phương pháp nén từ lựa chọn được khách hàng đưa ra. Có thể gửi một phiên id làm phần tin nhắn thực hiện quá trình thương lượng nối tiếp
- 3: Yêu cầu giấy chứng nhận từ khách hàng để kết nối có thể được cả hai bên chứng thực, sử dụng tin nhắn *CertificateRequest*



4: Cho biết nó đã thực hiện quá trình thương lượng. Khách hàng phản hồi bằng tin nhắn *Certificate* có chứa giấy chứng nhận của khách hàng

5: Có thể có chứa PreMasterSecret, khóa công cộng hoặc không có gì. PreMasterSecret được mã hóa bằng cách sử dụng khóa công cộng của giấy chứng nhận máy chủ

Client gửi tin nhắn *CertificateVerify*, nó là một chữ ký trên các tin nhắn trước có sử dụng khóa cá nhân trong giấy chứng nhận của khách hàng. Điều này sẽ giúp cho máy chủ biết được khách hàng truy cập vào khóa cá nhân và sở hữu giấy chứng nhận đó



Sau đó, khách hàng và máy chủ sẽ sử dụng các số ngẫu nhiên và PreMasterSecret để tính toán bí mật chung, được gọi là "master secret" (bí mật chính). Tất cả các dữ liệu khóa khác được sử dụng cho kết nối này đều xuất phát từ bí mật chính này (các giá trị ngẫu nhiên được khách hàng và máy chủ tạo ra), thông qua một "hàm giả ngẫu nhiên" được thiết kế một cách cẩn trọng

6: Chủ yếu để cho máy chủ biết rằng: "Từ bây giờ, mọi điều mà tôi nói với bạn đều sẽ được chứng thực (và được mã hóa nếu có thương lượng về điều đó)."



7: Tin nhắn *Finished* đã mã hóa, nó có chứa một giá trị băm và MAC trên các tin nhắn thương lượng trước

8: Server giải mã tin nhắn *Finished* của khách hàng và xác nhận giá trị băm cùng MAC đó.

Cho khách hàng biết " Từ bây giờ, mọi điều mà tôi nói với bạn đều sẽ được chứng thực (và được mã hóa nếu có thương lượng về điều đó)".

9: Tin nhắn *Finished* mã hóa của chính mình.

Khách hàng thực hiện sự giải mã và xác nhận tương tự

Tại thời điểm này quá trình thương lượng được hoàn tất.



6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.1 Định nghĩa

- ❖ **Giao dịch điện tử an toàn (SET) là một mã hóa mã và đặc tả thiết kế an toàn được thiết kế để bảo vệ giao dịch bằng thẻ tín dụng trên Internet.**
- ❖ **SET không phải là hệ thống thanh toán. Nó là một tập những giao thức an ninh và định dạng mà cho phép người dùng sử dụng phương tiện thanh toán thẻ tín dụng tồn tại trên một mạng mở, như Internet trong một cách thức an toàn**

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.2 Các dịch vụ của SET

- ❖ Cung cấp một kênh truyền thông an ninh giữa tất cả các người tham gia trong một giao dịch.
- ❖ Cung cấp sự tin cậy bằng cách sử dụng chứng nhận số X.509v3
- ❖ Bảo đảm tính riêng tư do thông tin chỉ sẵn có cho những người tham gia trong giao dịch khi nào cần thiết và ở nơi cần thiết

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.3 Các yêu cầu của SET

- ❖ Cung cấp sự tin tưởng cho người trả và thông tin.
- ❖ Bảo đảm sự toàn vẹn của tất cả thông tin truyền.
- ❖ Cung cấp sự chứng thực cho cardholder là người dùng hợp pháp của tài khoản thẻ tín dụng

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.3 Các yêu cầu của SET

- ❖ Cung cấp sự chứng thực rằng người bán có thể giao dịch bằng thẻ tín dụng qua quan hệ của nó với một viện tài chính.
- ❖ Bảo đảm việc dùng những phương cách an ninh thực tiễn tốt nhất và những kỹ thuật thiết kế hệ thống để bảo vệ tất cả những người tham gia hợp pháp trong giao dịch thương mại điện tử.

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.3 Các yêu cầu của SET

- ❖ Tạo ra một giao thức mà không phụ thuộc kỹ thuật an ninh vận chuyển cũng như không ngăn ngừa việc dùng chúng.
- ❖ Thuận tiện và hỗ trợ khả năng tác động giữa phần mềm và mạng.

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

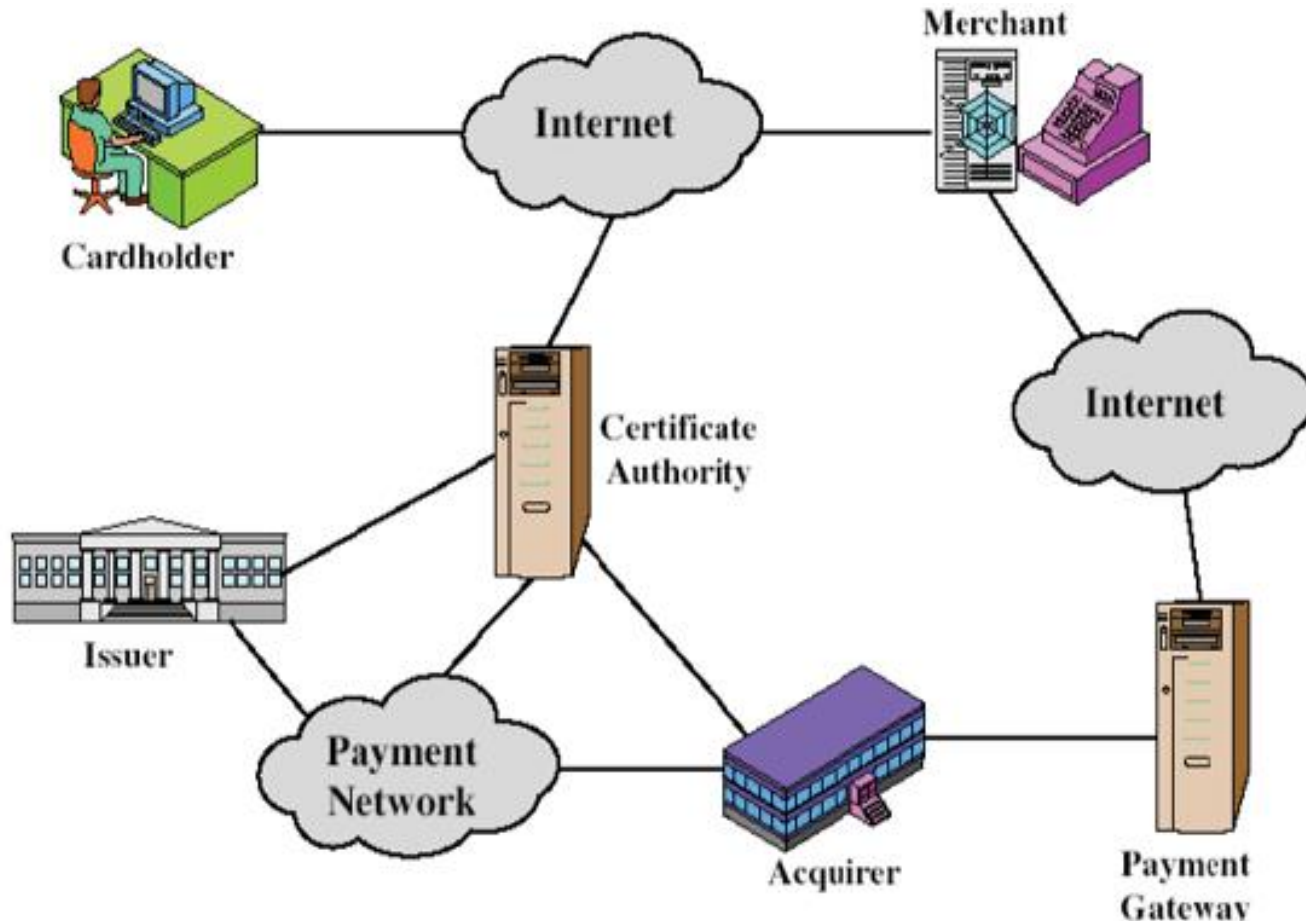
6.3.2.4 Các đặc trưng khóa của SET

- ❖ Sự tin cậy của thông tin.
- ❖ Sự toàn vẹn của dữ liệu.
- ❖ Chứng thực tài khoản Cardholder
- ❖ Chứng thực người bán

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.5 Các thành phần tham gia



6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.6 Trình tự các sự kiện

- ❖ Khách hàng mở một tài khoản.
- ❖ Khách hàng nhận một chứng nhận.
- ❖ Người bán có chứng nhận riêng của họ
- ❖ Khách hàng đặt một đơn hàng
- ❖ Người bán được kiểm tra

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.6 Trình tự các sự kiện

- ❖ Đơn hàng và cách thức thanh toán được gửi.
- ❖ Người bán yêu cầu sự cho phép thanh toán.
- ❖ Người bán xác nhận đơn hàng
- ❖ Người bán cung cấp hàng hóa và dịch vụ
- ❖ Người bán yêu cầu thanh toán

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

- ❖ Yêu cầu mua (Purchase request).
- ❖ Cấp quyền thanh toán (Payment authorization)
- ❖ Đạt được thanh toán (Payment capture)

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

- ❑ Trao đổi yêu cầu mua gồm 4 Msg: **Initiate Request**, **Initiate Response**, **Purchase Request**, và **Purchase Response**.
- ❑ **Initiate Request**: bao gồm các thương hiệu của thẻ tín dụng mà khách hàng đang sử dụng; một ID giao cho cặp yêu cầu/đáp ứng này của khách hàng và một nonce sử dụng để đảm bảo kịp thời

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

- ❑ Initiate Response: tạo ra một phản hồi và các dấu hiệu với chữ ký riêng của nó. Phản hồi này bao gồm: Nonce từ khách hàng, nonce khác cho các khách hàng trở lại trong thư tiếp theo, và một ID giao dịch cho giao dịch mua, giấy chứng nhận chữ ký của thương nhân và giấy chứng nhận trao đổi khóa của cổng thanh toán.
- ❑ Purchase Request:
 - Cardholder tạo một khóa mã hóa đối xứng một lần Ks
 - Cardholder tạo Purchase Request message

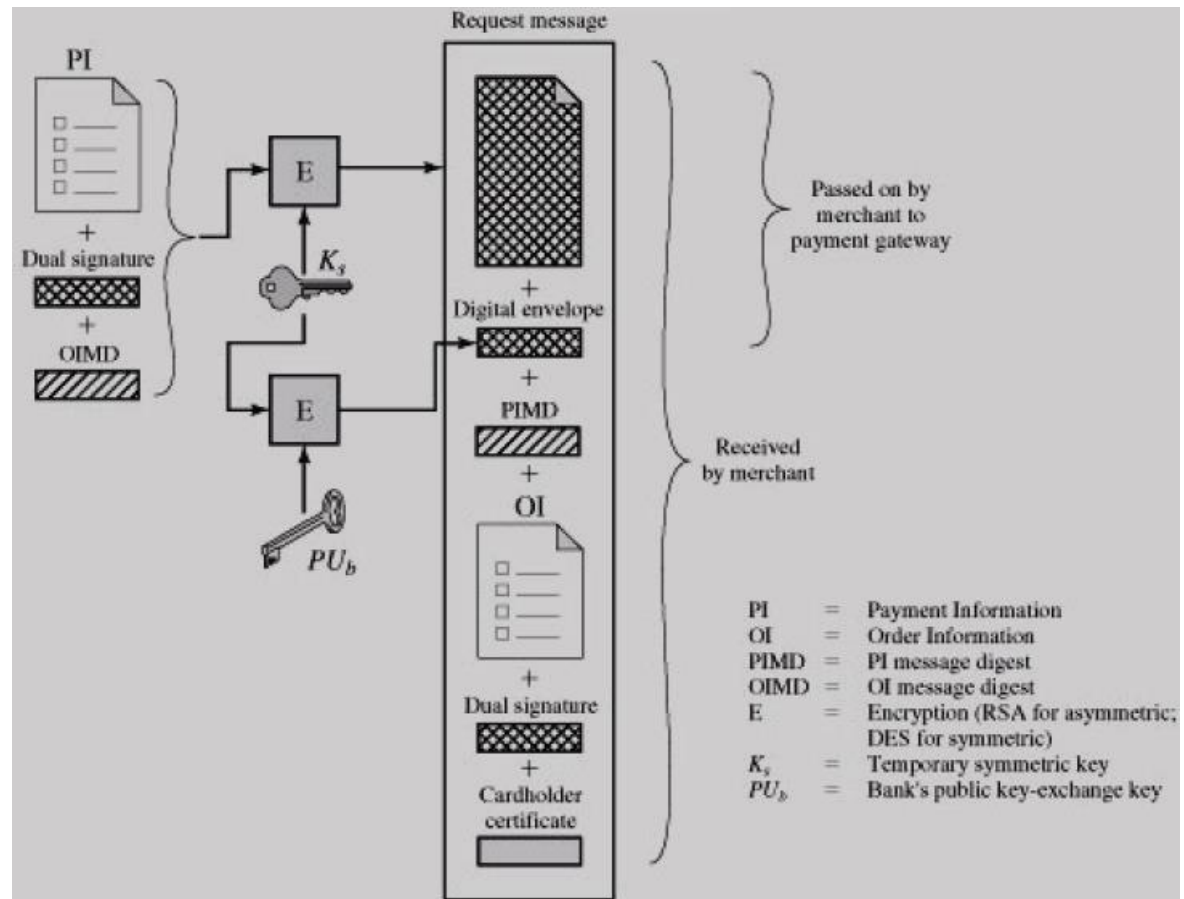
6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

Mô hình của
Purchase
Request:



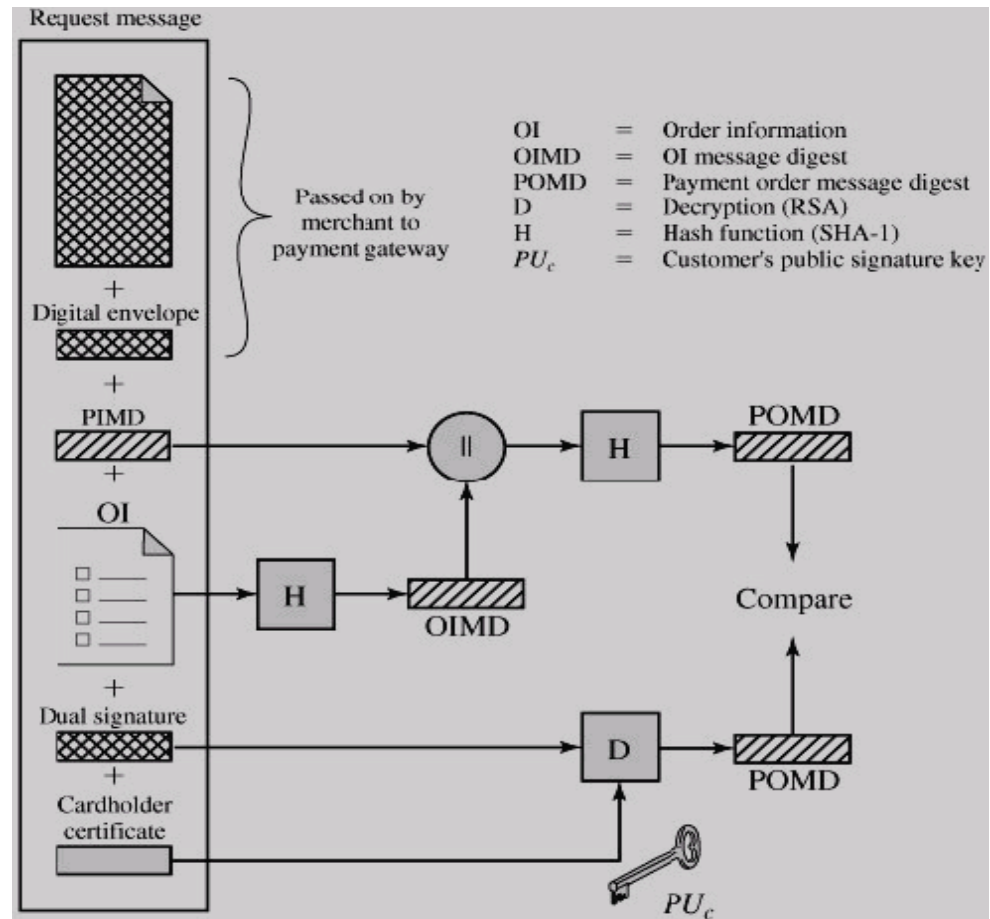
6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

Người bán
kiểm tra:



6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

- Hoạt động của người bán:

- +Kiểm tra chứng nhận của cardholder bằng phương tiện chữ ký CA của nó.

- +Kiểm tra dual signature dùng khóa chữ ký công cộng của khách hàng. Điều này bảo đảm rằng đơn hàng không bị thay đổi trong khi truyền và nó được ký bằng chữ ký riêng của cardholder

- +Xử lý đơn hàng và chuyển thông tin thanh toán tới cổng thanh toán cho việc cấp phép

- +Gửi purchase response tới cardholder

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Yêu cầu mua

- ❑ Purchase Response bao gồm: một khối đáp ứng thừa nhận đơn hàng và tham chiếu số giao dịch tương ứng. Khối này được ký bởi người bán dùng khóa chữ ký riêng của họ.

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Cấp quyền thanh toán

- ❑ Suốt quá trình xử lý đơn hàng từ cardholder, người bán giao dịch với cổng thanh toán. Việc cấp phép thanh toán bảo đảm rằng giao dịch đã được chấp thuận bởi Issuer, người bán có thể cung cấp hàng hóa hay dịch vụ cho khách hàng.
- ❑ Trao đổi cấp phép thanh toán gồm 2 Msg: **Authorization Request** và **Authorization response**

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Cấp quyền thanh toán

□ Authorization Request:

- Purchase-related information (Thông tin này nhận từ khách hàng)
- Authorization-related information (Authorization block gồm transaction ID, Digital envelope)
- Certificates:
 - + Bao gồm the cardholder's signature key certificate (dùng để kiểm tra dual signature)
 - + The merchant's signature key certificate (dùng để kiểm tra chữ ký của người bán)

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Cấp quyền thanh toán

- Việc thực hiện của Payment gateway:
 - +Kiểm tra tất cả các chứng nhận
 - +Kiểm tra chữ ký của người bán trên Authorization block
 - + Kiểm tra dual signature
 - + Kiểm tra transaction ID nhận từ người bán trùng với transaction ID trong PI nhận từ khách hàng
 - + Yêu cầu và nhận giấy phép từ Issuer

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Cấp quyền thanh toán

□ Authorization response :

- Authorization-related information: bao gồm authorization được ký với khóa chữ ký riêng của gateway và mã hóa với khóa đối xứng dùng một lần. Nó cũng gồm một digital envelope mà chứa khóa dùng một lần được mã hóa bằng public key-exchange key của người bán
- Capture token information: được dùng để thực hiện việc thanh toán sau đó, token này không được xử lý bởi người bán
- Chứng nhận của gateway

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Đạt được thanh toán

❑ Để đạt được việc thanh toán, người bán phối hợp với cổng thanh toán trong giao dịch đạt được thanh toán, gồm có **capture request** và **capture response message**.

❑ Capture request:

- Người bán tạo, ký và mã hóa những khối bao gồm số lượng thanh toán và transaction ID
- Msg cũng bao gồm capture token được mã hóa mà nhận được trước đó (trong **Authorization Response**) cho giao dịch này

6.3. Một số giải pháp an toàn cho HTTT

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Đạt được thanh toán

□ Capture response :

- Khi cổng thanh toán nhận capture request message nó giải mã và kiểm tra khối capture request block, giải mã và kiểm tra khối capture token.
- Nó kiểm tra tính toàn vẹn giữa capture request và capture token
- Nó tạo một clearing request gửi tới Issuer trên mạng thanh toán riêng. Yêu cầu này cho phép tiền được chuyển tới tài khoản người bán

6.3. Một số giải pháp an toàn cho HTTP

6.3.2. Giao dịch điện tử an toàn (SET)

6.3.2.7 Xử lý thanh toán

❖ Đạt được thanh toán

- Cổng thanh toán khi đó thông báo cho người bán việc thanh toán trong một **Capture Response message**
- Msg có một khối capture response mà cổng đã ký và mã hóa. Phần mềm của người bán lưu trữ capture response để làm căn cứ cho việc thanh toán nhận từ người thu

6.4. Một số giải pháp an toàn cho người dùng



Thank You !